

What is Social Engineering?

Social Engineering is the art of manipulating people into revealing confidential information or performing actions that compromise security.

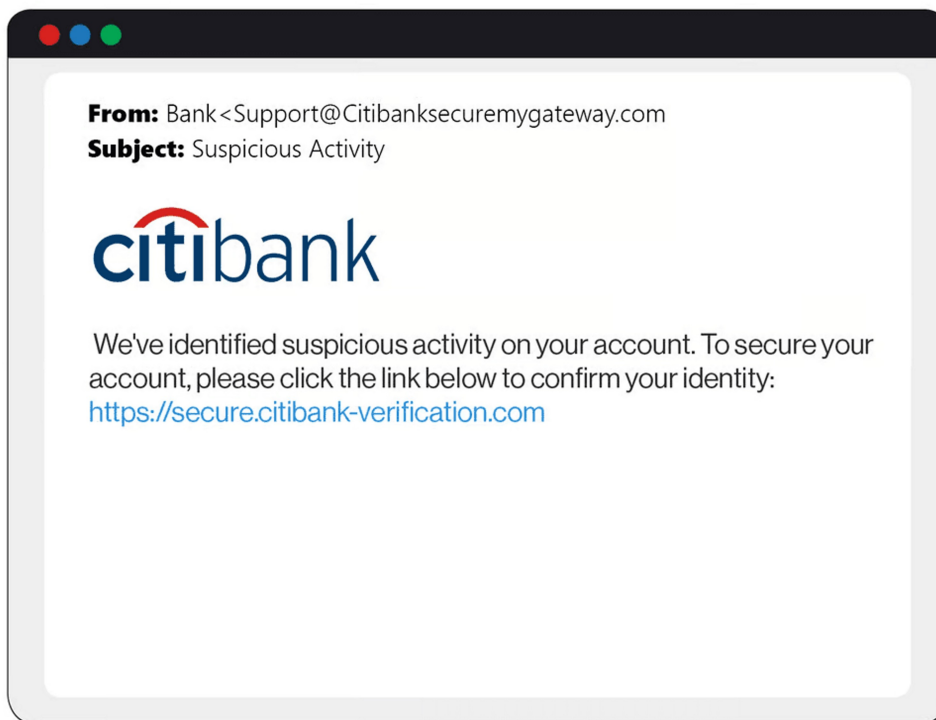
 Instead of hacking a system, social engineers "hack" **human trust**.

Types of Social Engineering Attacks

Phishing

Mass email pretending to be a bank, service, or boss asking you to click a link or enter credentials.

Example: "Your mailbox is full — click here to log in."



Spear-phishing

Targeted phishing that is personalized (uses your name, company, role). Much more convincing.

Example: an email to HR appearing to come from the CEO asking for payroll spreadsheet.

Business Email Compromise (BEC)

Attacker spoofs or compromises an executive's email and instructs finance to transfer funds.

Example: "Urgent wire transfer to this vendor — do it now."

Vishing (voice phishing)

Phone call impersonating support, bank, or colleague to extract passwords, codes, or to get helpdesk to reset accounts.

Smishing (SMS phishing)

Text messages with malicious links or codes — e.g., "Verify your package" with a link.

Pretexting

Attacker builds a believable story (pretext) and asks for specific info — often used to get helpdesk to reset passwords or reveal data.

Baiting

Attacker leaves a tempting physical item (USB stick) or offer to lure victims to open it and install malware.

Quid pro quo

Attacker offers a service (e.g., IT help) in exchange for credentials or actions.

Tailgating / Piggybacking (physical)

Following someone through a secure door by pretending to belong or by asking them to "hold the door".

Water-holing

Compromise a website that a target group visits often (university portal, supplier portal) and infect visitors.

Deepfake / Synthetic Media

Use of realistic fake audio/video to impersonate executives or customers (used to authorize actions).

Tools for Social Engineering Attacks

Tool	Use Case
SET (Social Engineering Toolkit)	Create phishing sites, fake emails, USB payloads
Evilginx2	Advanced phishing using man-in-the-middle
Gophish	Email phishing campaign testing
Bettercap	ARP spoofing + HTTPS stripping for fake login pages
Fluxion	Wi-Fi Evil Twin + Phishing
MSFvenom + USB Rubber Ducky	Create infected USB payloads

Common Targets

- HR employees (receive many resumes/emails)
- Finance department (can approve payments)
- Customer support (handle sensitive info)
- Home users (easy phishing target)

How to Protect Against Social Engineering

Layer	Protection
Training	Educate employees about phishing & scams
Multi-Factor Auth (MFA)	Password alone is not enough
Email Filtering	Block suspicious attachments/links
Caller Verification	Always verify unknown callers
No Password Sharing	Even with IT or seniors
Use of Antivirus	Detect USB or file-based attacks
HTTPS Sites Only	Check for secure padlock on login pages

Real-World Case Study

Target Corp. (2013)

- Attackers phished an HVAC vendor.
- Got access to Target's internal systems.
- Stole **40 million** credit card numbers.

Lesson: A weak link (vendor) can compromise entire system.

Ethical Hacking Lab Example (Using SET)

sudo setoolkit

- Choose: 1) Social-Engineering Attacks
- Then: 2) Website Attack Vectors
- Then: 3) Credential Harvester Attack Method
- Enter your IP and choose a template (e.g., Facebook)
- Send the link to victim

 If victim enters login, you get:

[*] Username: testuser

[*] Password: 123456